

SCENARIO 2 — PROJECT DESCRIPTION

Project Title

LLM-Integrated Secure File Management System

Project Overview

The system is a secure file-management platform that allows authenticated users to upload, store, retrieve, and interact with documents through an AI-powered file assistant.

The system combines conventional web application functionality, file storage, authentication, authorization, access-control enforcement, and an external Large Language Model (LLM) provider.

The primary security objectives are to preserve the **confidentiality, integrity, availability, ownership, and access-control correctness of user files**, while allowing authorized users to ask natural-language questions about documents.

The external LLM is used only as an AI assistance component. The LLM must **not** independently authenticate users, make authorization decisions, modify files, modify permissions, retrieve files directly, or bypass application access-control mechanisms.

Security Zones

The system contains four security zones.

Zone A — External User Environment

Zone A is an **untrusted, user-controlled environment** containing the end user and browser/client device.

The user can:

- upload files;
- request file retrieval;
- provide filenames and metadata;
- identify documents;
- submit natural-language questions;
- interact with the AI assistant.

All information originating from Zone A must be treated as potentially malicious or attacker-controlled.

Zone B — Application Environment

Zone B contains the trusted application logic:

- **P1 — Web Frontend Interface**
- **P2 — File Management Service**

- **P3 — AI File Assistant**
- **P4 — LLM Integration Service**

Although these components are inside the application environment, user-controlled data entering through P1 remains untrusted.

Zone C — Data Layer

Zone C contains protected persistent data:

- **DS1 — Server Storage Repository**
- **DS2 — User / Permission Database**

DS1 stores uploaded files, document contents, and file metadata.

DS2 stores user identity, file ownership, and access permissions and acts as the authoritative source for authorization decisions.

Zone D — External LLM Provider

Zone D contains:

- **EE2 — External LLM Provider**

The external LLM provider is a third-party service outside the application's direct security control.

The application sends prompts and **only previously authorized document context** to the provider.

The provider's generated output must be considered untrusted.

Components

P1 — Web Frontend Interface

P1 is the user-facing interface.

It receives:

- file-upload requests;
- file-retrieval requests;
- document identifiers;
- metadata;
- natural-language questions.

P1 forwards file-management operations to P2 and AI-related questions to P3.

P1 must not be considered a trusted source for user-controlled data.

P2 — File Management Service

P2 is the primary file-management and authorization-enforcement component.

P2 is responsible for:

- validating uploaded files;
- processing file metadata;
- storing validated files;
- processing authenticated file-access requests;
- verifying authorization through DS2;
- retrieving authorized files from DS1;
- enforcing file ownership and permission restrictions;
- providing authorized document context to P3.

P2 is the **primary enforcement point for file authorization**.

Authorization must be associated with the specific authenticated user, requested file/object, and requested operation.

P3 — AI File Assistant

P3 provides document-related AI assistance.

P3 receives:

- the authenticated user's question;
- the requested document identifier;
- relevant authenticated user/session context.

P3 does **not** independently determine whether the user is authorized to access the document.

Instead, P3 requests the required document context from P2.

P2 verifies authorization using DS2 and retrieves the corresponding document content from DS1 only if access is permitted.

P3 receives only the **approved document context** returned by P2.

P3 then combines the user's question with the approved context and sends it to P4.

The AI assistant must never bypass P2, DS2, or the application's existing authorization controls.

P4 — LLM Integration Service

P4 communicates with the external LLM provider.

P4 receives:

- the user's natural-language question;
- approved document context.

P4 constructs the LLM prompt and sends it to EE2.

P4 receives generated output from EE2 and returns the response to P3.

The external LLM is outside the application's security control.

Data Stores

DS1 — Server Storage Repository

Stores:

- uploaded files;
- document contents;
- file metadata.

Files originate from users and therefore may contain malicious content or attacker-controlled text.

DS2 — User / Permission Database

Stores:

- authenticated user identity;
- file ownership;
- access permissions.

DS2 is the authoritative source for file authorization decisions.

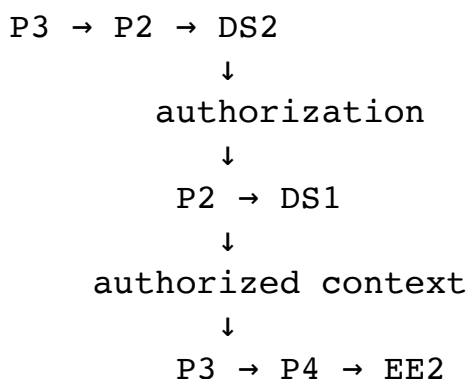
Authorization failures or unavailable authorization information must never result in access being granted.

Required Authorization Architecture

The following rule is mandatory:

The AI assistant must never obtain document context directly from DS1.

Instead:



Therefore, a user cannot cause the AI assistant to send an unauthorized document to the external LLM merely by supplying a document identifier or manipulating an AI prompt.

Data Flows

Use these flows in the architecture and threat-model description.

DF1 — File Upload Request

EE1 sends a file-upload request to P1.

DF2 — Uploaded File + Metadata

P1 forwards the uploaded file and associated metadata to P2.

DF3 — Validated File Storage Request

P2 validates the upload and sends validated file information to DS1.

DF4 — File Retrieval Request

EE1 requests a specific file through P1.

DF5 — Authenticated File Access Request

P1 forwards the authenticated user's file-access request to P2.

DF6 — Authorization Verification Request

P2 sends the authenticated user identity, requested file identifier, and requested operation to DS2 for authorization verification.

DF7 — Authorization Decision

DS2 returns an allow/deny authorization decision to P2.

DF8 — Authorized File Lookup

After a successful authorization decision, P2 requests the authorized file from DS1.

DF9 — Requested File Content

DS1 returns the requested file content and relevant metadata to P2.

DF10 — Retrieved File

P2 returns the authorized file to P1 for presentation to the user.

DF11 — Document Question

EE1 submits a natural-language document-related question through P1.

DF12 — AI Question + User/Document Context

P1 forwards the authenticated user context, requested document identifier, and natural-language question to P3.

DF13 — Authorized Context Request

P3 requests document context from P2 for the authenticated user and specified document.

DF14 — Authorization Verification

P2 verifies whether the user is authorized to access the requested document by consulting DS2.

DF15 — Authorization Decision

DS2 returns the authorization decision to P2.

DF16 — Authorized Document Retrieval

If authorization succeeds, P2 retrieves the required document content from DS1.

DF17 — Approved Document Context

P2 returns only the authorized document context to P3.

DF18 — Prompt + Approved Context

P3 combines the user's question with the approved document context and sends it to P4.

DF19 — Prompt + Approved Context

P4 sends the assembled prompt and approved context across TB4 to EE2.

DF20 — Generated LLM Response

EE2 returns generated model output to P4.

DF21 — Processed AI Response

P4 returns the processed LLM response to P3.

DF22 — Generated Answer

P3 returns the generated answer to P1.

DF23 — Answer Display

P1 presents the generated answer to EE1.

Trust Boundaries

TB1 — External User / Application Boundary

Separates Zone A from Zone B.

User-controlled:

- files;
- filenames;
- metadata;
- file IDs;
- retrieval requests;
- questions;
- prompt content.

TB2 — Application / Data Layer Boundary

Separates Zone B from Zone C.

Crossings include:

- P2 ↔ DS1;
- P2 ↔ DS2.

TB3 — Authorization Data Boundary

Represents the security boundary around authorization information exchanged between P2 and DS2.

DS2 is authoritative for ownership and permission decisions.

TB4 — Application / External LLM Boundary

Separates Zone B from Zone D.

P4 sends:

- user questions;
 - approved document context;
- to EE2.

The external provider is outside the application's direct security control.

Critical Security Requirements

The threat model must consider the following requirements:

1. Only authenticated users may perform file-management operations.
2. Authentication alone must not grant access to every file.
3. Authorization must be enforced for the specific user, file/object, and operation.
4. File IDs, filenames, metadata, and request parameters are untrusted.
5. Uploaded files must be validated before storage.
6. File content and metadata may contain malicious content.
7. Stored files must be protected against unauthorized access.
8. File ownership and permissions must not be modifiable by unauthorized users.
9. File retrieval must occur only after successful authorization.
10. Authorization failure or unavailability must fail closed.
11. Retrieved file content must not automatically be treated as safe active content.
12. AI processing must use only document context that the requesting user is authorized to access.
13. P3 must not bypass P2 for document retrieval.
14. The LLM must never be treated as an authorization authority.
15. User questions are untrusted natural-language input.
16. Uploaded documents may contain malicious instructions that can cause indirect prompt injection.
17. Prompt construction must separate trusted application instructions from untrusted user/document content.
18. Sensitive document information sent to the external LLM should be minimized.
19. Generated LLM responses are untrusted.
20. LLM output must not automatically be executed or treated as authoritative instructions.
21. Different users' files, permissions, prompts, document contexts, and responses must remain isolated.
22. External LLM credentials must not be exposed.
23. File-management and AI-assistant functionality must be protected against denial-of-service and resource exhaustion.
24. File access, authorization decisions, uploads, and AI operations should be logged and monitored.
25. The threat analysis must cover both conventional application/file-management vulnerabilities and LLM-specific vulnerabilities.

These requirements are consistent with the supplied Scenario 2 specification, including its explicit requirements for authorization enforcement, malicious uploaded content, prompt injection, external-provider exposure, untrusted LLM output, isolation, and availability.

SCENARIO 2 — PROJECT DESCRIPTION

Project Title

LLM-Integrated Secure File Management System

Project Overview

The system is a secure file-management platform that allows authenticated users to upload, store, retrieve, and interact with documents through an AI-powered file assistant.

The system combines conventional web application functionality, file storage, authentication, authorization, access-control enforcement, and an external Large Language Model (LLM) provider.

The primary security objectives are to preserve the **confidentiality, integrity, availability, ownership, and access-control correctness of user files**, while allowing authorized users to ask natural-language questions about documents.

The external LLM is used only as an AI assistance component. The LLM must **not** independently authenticate users, make authorization decisions, modify files, modify permissions, retrieve files directly, or bypass application access-control mechanisms.

Security Zones

The system contains four security zones.

Zone A — External User Environment

Zone A is an **untrusted, user-controlled environment** containing the end user and browser/client device.

The user can:

- upload files;
- request file retrieval;
- provide filenames and metadata;
- identify documents;
- submit natural-language questions;
- interact with the AI assistant.

All information originating from Zone A must be treated as potentially malicious or attacker-controlled.

Zone B — Application Environment

Zone B contains the trusted application logic:

- **P1 — Web Frontend Interface**
- **P2 — File Management Service**
- **P3 — AI File Assistant**
- **P4 — LLM Integration Service**

Although these components are inside the application environment, user-controlled data entering through P1 remains untrusted.

Zone C — Data Layer

Zone C contains protected persistent data:

- **DS1 — Server Storage Repository**
- **DS2 — User / Permission Database**

DS1 stores uploaded files, document contents, and file metadata.

DS2 stores user identity, file ownership, and access permissions and acts as the authoritative source for authorization decisions.

Zone D — External LLM Provider

Zone D contains:

- **EE2 — External LLM Provider**

The external LLM provider is a third-party service outside the application's direct security control.

The application sends prompts and **only previously authorized document context** to the provider.

The provider's generated output must be considered untrusted.

Components

P1 — Web Frontend Interface

P1 is the user-facing interface.

It receives:

- file-upload requests;
- file-retrieval requests;
- document identifiers;
- metadata;
- natural-language questions.

P1 forwards file-management operations to P2 and AI-related questions to P3.

P1 must not be considered a trusted source for user-controlled data.

P2 — File Management Service

P2 is the primary file-management and authorization-enforcement component.

P2 is responsible for:

- validating uploaded files;
- processing file metadata;
- storing validated files;
- processing authenticated file-access requests;
- verifying authorization through DS2;
- retrieving authorized files from DS1;
- enforcing file ownership and permission restrictions;
- providing authorized document context to P3.

P2 is the **primary enforcement point for file authorization**.

Authorization must be associated with the specific authenticated user, requested file/object, and requested operation.

P3 — AI File Assistant

P3 provides document-related AI assistance.

P3 receives:

- the authenticated user's question;
- the requested document identifier;
- relevant authenticated user/session context.

P3 does **not** independently determine whether the user is authorized to access the document.

Instead, P3 requests the required document context from P2.

P2 verifies authorization using DS2 and retrieves the corresponding document content from DS1 only if access is permitted.

P3 receives only the **approved document context** returned by P2.

P3 then combines the user's question with the approved context and sends it to P4.

The AI assistant must never bypass P2, DS2, or the application's existing authorization controls.

P4 — LLM Integration Service

P4 communicates with the external LLM provider.

P4 receives:

- the user's natural-language question;
- approved document context.

P4 constructs the LLM prompt and sends it to EE2.

P4 receives generated output from EE2 and returns the response to P3.

The external LLM is outside the application's security control.

Data Stores

DS1 — Server Storage Repository

Stores:

- uploaded files;
- document contents;

- file metadata.

Files originate from users and therefore may contain malicious content or attacker-controlled text.

DS2 — User / Permission Database

Stores:

- authenticated user identity;
- file ownership;
- access permissions.

DS2 is the authoritative source for file authorization decisions.

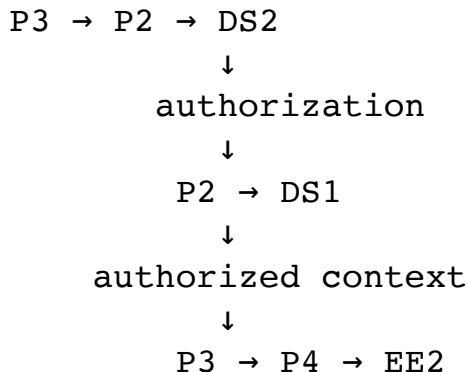
Authorization failures or unavailable authorization information must never result in access being granted.

Required Authorization Architecture

The following rule is mandatory:

The AI assistant must never obtain document context directly from DS1.

Instead:



Therefore, a user cannot cause the AI assistant to send an unauthorized document to the external LLM merely by supplying a document identifier or manipulating an AI prompt.

Data Flows

Use these flows in the architecture and threat-model description.

DF1 — File Upload Request

EE1 sends a file-upload request to P1.

DF2 — Uploaded File + Metadata

P1 forwards the uploaded file and associated metadata to P2.

DF3 — Validated File Storage Request

P2 validates the upload and sends validated file information to DS1.

DF4 — File Retrieval Request

EE1 requests a specific file through P1.

DF5 — Authenticated File Access Request

P1 forwards the authenticated user's file-access request to P2.

DF6 — Authorization Verification Request

P2 sends the authenticated user identity, requested file identifier, and requested operation to DS2 for authorization verification.

DF7 — Authorization Decision

DS2 returns an allow/deny authorization decision to P2.

DF8 — Authorized File Lookup

After a successful authorization decision, P2 requests the authorized file from DS1.

DF9 — Requested File Content

DS1 returns the requested file content and relevant metadata to P2.

DF10 — Retrieved File

P2 returns the authorized file to P1 for presentation to the user.

DF11 — Document Question

EE1 submits a natural-language document-related question through P1.

DF12 — AI Question + User/Document Context

P1 forwards the authenticated user context, requested document identifier, and natural-language question to P3.

DF13 — Authorized Context Request

P3 requests document context from P2 for the authenticated user and specified document.

DF14 — Authorization Verification

P2 verifies whether the user is authorized to access the requested document by consulting DS2.

DF15 — Authorization Decision

DS2 returns the authorization decision to P2.

DF16 — Authorized Document Retrieval

If authorization succeeds, P2 retrieves the required document content from DS1.

DF17 — Approved Document Context

P2 returns only the authorized document context to P3.

DF18 — Prompt + Approved Context

P3 combines the user's question with the approved document context and sends it to P4.

DF19 — Prompt + Approved Context

P4 sends the assembled prompt and approved context across TB4 to EE2.

DF20 — Generated LLM Response

EE2 returns generated model output to P4.

DF21 — Processed AI Response

P4 returns the processed LLM response to P3.

DF22 — Generated Answer

P3 returns the generated answer to P1.

DF23 — Answer Display

P1 presents the generated answer to EE1.

Trust Boundaries

TB1 — External User / Application Boundary

Separates Zone A from Zone B.

User-controlled:

- files;
- filenames;

- metadata;
- file IDs;
- retrieval requests;
- questions;
- prompt content.

TB2 — Application / Data Layer Boundary

Separates Zone B from Zone C.

Crossings include:

- P2 ↔ DS1;
- P2 ↔ DS2.

TB3 — Authorization Data Boundary

Represents the security boundary around authorization information exchanged between P2 and DS2.

DS2 is authoritative for ownership and permission decisions.

TB4 — Application / External LLM Boundary

Separates Zone B from Zone D.

P4 sends:

- user questions;
 - approved document context;
- to EE2.

The external provider is outside the application's direct security control.

Critical Security Requirements

The threat model must consider the following requirements:

1. Only authenticated users may perform file-management operations.
2. Authentication alone must not grant access to every file.
3. Authorization must be enforced for the specific user, file/object, and operation.
4. File IDs, filenames, metadata, and request parameters are untrusted.
5. Uploaded files must be validated before storage.
6. File content and metadata may contain malicious content.
7. Stored files must be protected against unauthorized access.
8. File ownership and permissions must not be modifiable by unauthorized users.
9. File retrieval must occur only after successful authorization.
10. Authorization failure or unavailability must fail closed.
11. Retrieved file content must not automatically be treated as safe active content.

12. AI processing must use only document context that the requesting user is authorized to access.
13. P3 must not bypass P2 for document retrieval.
14. The LLM must never be treated as an authorization authority.
15. User questions are untrusted natural-language input.
16. Uploaded documents may contain malicious instructions that can cause indirect prompt injection.
17. Prompt construction must separate trusted application instructions from untrusted user/document content.
18. Sensitive document information sent to the external LLM should be minimized.
19. Generated LLM responses are untrusted.
20. LLM output must not automatically be executed or treated as authoritative instructions.
21. Different users' files, permissions, prompts, document contexts, and responses must remain isolated.
22. External LLM credentials must not be exposed.
23. File-management and AI-assistant functionality must be protected against denial-of-service and resource exhaustion.
24. File access, authorization decisions, uploads, and AI operations should be logged and monitored.
25. The threat analysis must cover both conventional application/file-management vulnerabilities and LLM-specific vulnerabilities.

These requirements are consistent with the supplied Scenario 2 specification, including its explicit requirements for authorization enforcement, malicious uploaded content, prompt injection, external-provider exposure, untrusted LLM output, isolation, and availability.